

Segurança das chaves de API — YT PWA

Guia para proteger as chaves usadas pelo app · Repositório: github.com/Thiago-spba/YT---PWA

1. O contexto (por que isto importa)

O YT PWA não tem backend próprio: o navegador fala direto com a API do YouTube. Toda variável de ambiente com prefixo `VITE_` é **embutida no bundle JavaScript** durante o build — ou seja, fica visível para qualquer pessoa que abra o site publicado e inspecione o código. Isso não é um bug; é como apps sem backend funcionam. O que muda a segurança é *onde* a chave está e *se* há restrições do lado do provedor.

✓ O que já está seguro (verificado)

- **ANTHROPIC_API_KEY**: usada só no servidor (Vercel Function `api/search-expand.ts`, via `process.env`). Nunca tem prefixo `VITE_`, nunca vai para o frontend.
- O arquivo `.env` (com as chaves reais) está no `.gitignore` e **nunca** foi versionado — confirmado no histórico completo do Git.
- Só o `.env.example` (placeholders vazios) está no repositório.
- Nenhuma chave hardcoded no código-fonte.

⚠ O risco em aberto

`VITE_YOUTUBE_API_KEY` e `VITE_GOOGLE_CLIENT_ID` ficam **expostas no frontend**. Sem restrições no Google, um terceiro pode copiar a chave do YouTube e **queimar sua cota diária**. O Client ID do OAuth é público por design, mas as origens autorizadas precisam estar travadas.

Não é possível travar isso por código no frontend — a chave está em texto claro no navegador. A proteção só existe de duas formas, descritas abaixo.

2. Caminho 1 — Restringir no Google Cloud Console (recomendado; ~5 min, sem código)

É o caminho oficial e mais rápido. A chave continua no frontend, mas fica **inútil fora do seu domínio**.

2.1 Chave da YouTube Data API

1. Acesse console.cloud.google.com → **APIs e Serviços** → **Credenciais**.
2. Clique na sua **Chave de API** do YouTube.
3. Em **Restrições de aplicativo**, escolha **Referenciadores HTTP (sites)** e adicione:
 - `https://SEU-DOMINIO.vercel.app/*` (o domínio de produção)
 - `http://localhost:*` e `http://127.0.0.1:*` (para testes locais)

4. Em **Restrições de API**, marque **Restringir chave** e selecione só **YouTube Data API v3**.
5. Salvar. (A propagação pode levar alguns minutos.)

2.2 Client ID do OAuth (login Google)

1. Em **Credenciais**, abra o **ID do cliente OAuth 2.0** (tipo "Aplicativo da Web").
2. Em **Origens JavaScript autorizadas**, deixe só:
 - `https://SEU-DOMINIO.vercel.app`
 - `http://localhost:5173` (porta do Vite em dev, se usar)
3. Salvar.

⚠ Se a chave já ficou exposta sem restrição

Como o repositório é público e o app pode já ter sido publicado, o mais seguro é **gerar uma chave nova** no Google Cloud e criá-la *já* com as restrições acima; depois apague a antiga. Atualize `VITE_YOUTUBE_API_KEY` no `.env` local e nas variáveis de ambiente da Vercel.

3. Caminho 2 — Tirar a chave do frontend via proxy (opcional; mais seguro)

Feito **dentro da aplicação**: mover as chamadas ao YouTube para uma **Vercel Function**, exatamente como a Anthropic já funciona hoje. A chave vira `YOUTUBE_API_KEY` (sem `VITE_`), fica só no servidor, e o frontend chama `/api/youtube-...` em vez de `googleapis.com` direto. Assim a chave **nunca aparece no bundle**.

Passo	O que fazer
Nova Function	Criar <code>api/youtube.ts</code> que recebe a busca, lê <code>process.env.YOUTUBE_API_KEY</code> e repassa a resposta do YouTube.
Refatorar cliente	Em <code>src/lib/youtube.ts</code> , trocar as chamadas diretas (<code>searchVideos</code> , <code>searchVideosPage</code> , <code>getVideoById</code> , <code>getVideoFlags</code> , Shorts) por <code>fetch('/api/youtube?...')</code> .
Variáveis	Renomear <code>VITE_YOUTUBE_API_KEY</code> → <code>YOUTUBE_API_KEY</code> no <code>.env</code> e no painel da Vercel. Manter <code>VITE_GOOGLE_CLIENT_ID</code> (Client ID é público por natureza).
Rate limit	Reaproveitar o padrão de limite por IP já usado em <code>api/search-expand.ts</code> .

Custo: é uma mudança de arquitetura (não trivial), mas o app já tem o padrão pronto. **Mesmo com o proxy, mantenha o Caminho 1** como camada extra.

4. Checklist rápido

- ☐ Restringir a chave do YouTube por referenciador HTTP + só YouTube Data API v3
- ☐ Travar as origens JavaScript autorizadas do Client ID OAuth
- ☐ Gerar chave nova do YouTube (se a antiga já ficou exposta) e apagar a antiga
- ☐ Conferir que `.env` continua fora do Git (nunca commitar)

- ☐ (Opcional/futuro) Implementar o proxy da API do YouTube via Vercel Function
- ☐ (Opcional) Tornar o repositório privado no GitHub

Documento gerado para o projeto YT PWA · Guarde junto ao repositório · Sem chaves reais neste arquivo.